

How Attackers Use Nmap

A Cybersecurity Student's Breakdown

By K. Parth

Abstract

Nmap (Network Mapper) is one of the most widely used open-source tools in cybersecurity. While defenders use it for network auditing, attackers use it extensively during the reconnaissance phase to gather information about a target open ports, running services, operating system details, and network topology. This writeup breaks down how Nmap works, what scan types exist, what an attacker looks for in the results, and how defenders can detect and respond to Nmap scans.

1. Introduction

Nmap (Network Mapper) is a free and open source tool created by Gordon Lyon (also known as Fyodor) in 1997. It is used to discover hosts and services on a network by sending packets and analyzing the responses. On Windows, Nmap also comes with a graphical interface called **Zenmap**, which makes it easier to visualize network topology and scan results.

In cybersecurity, Nmap sits at the “**reconnaissance phase**”. Before an attacker can exploit anything, they need to know what exists on the network.

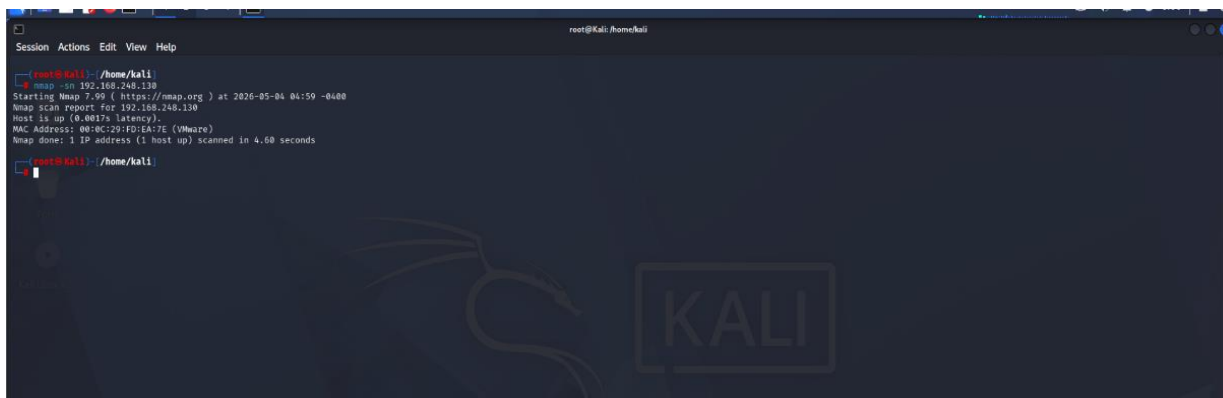
2. Types of Scans

Nmap supports multiple scan types, each designed for a specific purpose. The choice of scan depends on how stealthy the attacker needs to be and what information they want to collect.

Scan Type	Command
Ping Sweep	<code>nmap -sn 192.168.1.0/24</code>
SYN Scan	<code>nmap -sS <target></code>
TCP Connect	<code>nmap -sT <target></code>
UDP Scan	<code>nmap -sU <target></code>
Version Detection	<code>nmap -sV <target></code>
OS Detection	<code>nmap -O <target></code>
Aggressive Scan	<code>nmap -A <target></code>
Script Scan	<code>nmap -sC <target></code>

2.1.1 Ping Sweep :

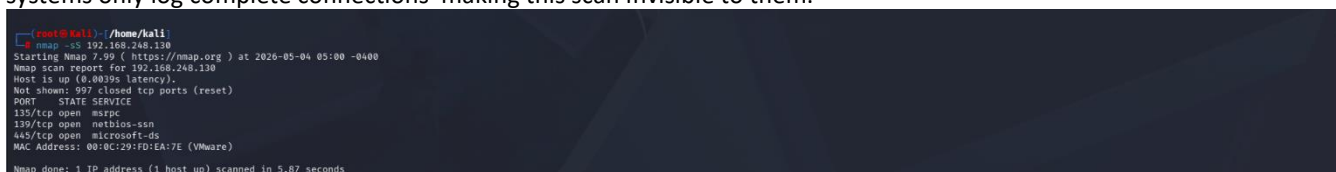
The ping sweep is used to scan whether the host is live or not. From the below picture we can see that the host is active and it shows that it is running on VMware machine.



```
root@kali: /home/kali
root@kali:~# nmap -sn 192.168.248.138
Starting Nmap 7.90 ( https://nmap.org ) at 2026-05-04 01:59 -0400
Nmap scan report for 192.168.248.138
Host is up (0.0017s latency).
MAC Address: 08:0C:29:FD:EA:7E (VMware)
Nmap done: 1 IP address (1 host up) scanned in 4.60 seconds
```

2.1.2 Syn Scan:

Attackers prefer the SYN scan (-sS) because it never completes the TCP three-way handshake. A SYN scan sends SYN, receives SYN-ACK, then immediately sends RST to close the connection before it is logged. Many older firewalls and IDS systems only log complete connections making this scan invisible to them.



```
root@kali: /home/kali
root@kali:~# nmap -sS 192.168.248.138
Starting Nmap 7.90 ( https://nmap.org ) at 2026-05-04 05:00 -0400
Nmap scan report for 192.168.248.138
Host is up (0.0039s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 08:0C:29:FD:EA:7E (VMware)
Nmap done: 1 IP address (1 host up) scanned in 5.87 seconds
```

2.1.3 TCP Connect:

A TCP scan checks which ports are available on a system by trying to communicate using the Transmission Control Protocol. It ensures three way handshake between the communication devices for reliable connection. TCP connection works in this way “SYN → SYN-ACK → ACK”, the TCP packet Header contains ,Sequence number, Acknowledge number, Source Port, Destination Port, Data Offset(indicates where the data actually starts). It has flags like SYN (start connection), ACK(acknowledge data), FIN(close the connection), RST(to terminate the connection).

From the image below the output of the TCP scan is:

- “Host is up (0.0015s latency)” here latency indicates the round trip time taken for a packet to travel from the source to the targeted system. And the output shows “Target system is alive and reachable”.
- “Not shown: 997 closed tcp ports (conn-refused)” Out of 1000 ports – 997 are closed.
- And these are the **open ports** :
 - 135/tcp open msrpc (Remote procedure calls (Windows))**
 - 139/tcp open netbios-ssn (File sharing)**
 - 445/tcp open microsoft-ds (Windows file sharing)**

```

root@kali:~/home/kali
# nmap -sT 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 05:01 -0400
Nmap scan report for 192.168.248.130
Host is up (0.0015s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:FD:EA:7E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.83 seconds

```

2.1.4 UDP Scan :

The UDP scan is used to know open UDP ports by sending the UDP packets to the targeted machine, it's a connectionless protocol, unlike TCP connection (3- way handshake), the UDP does not have reliable connection, the UDP connection is faster than TCP connection, and **UDP scan** is slower than **TCP scan** because there is no response from the targeted machine. The ICMP (Internet Control Message Protocol) in the context of UDP packets serves as an error-reporting mechanism, notifying the sender when a UDP packet fails to reach its destination or cannot be processed.

From the below image the output is:

- “Host is up (0.0024s latency)” that means Target system is **alive**.
- Not shown: 992 closed UDP ports , which results in Out of 1000 UDP ports – 992 ports are closed.
- Open Ports (the ports are definitely)/ Open | Filtered Ports(ports may or may not be opened):

123/udp	open	ntp
137/udp	open	netbios-ns
138/udp	open filtered	netbios-dgm
445/udp	open filtered	microsoft-ds
500/udp	open filtered	isakmp
1900/udp	open filtered	upnp
4500/udp	open filtered	nat-t-ike

```

root@kali:~/home/kali
# nmap -sU 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 05:01 -0400
Nmap scan report for 192.168.248.130
Host is up (0.0024s latency).
Not shown: 992 closed udp ports (port-unreach)
PORT      STATE SERVICE
123/udp   open  ntp
137/udp   open  netbios-ns
138/udp   open|filtered netbios-dgm
445/udp   open|filtered microsoft-ds
500/udp   open|filtered isakmp
8025/udp  open|filtered blackjack
1900/udp  open|filtered upnp
4500/udp  open|filtered nat-t-ike
MAC Address: 00:0C:29:FD:EA:7E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.96 seconds
root@kali:~/home/kali

```

2.1.5 Script Scan :

A **script scan** uses the **Nmap Scripting Engine (NSE)** to run pre-written scripts against a target. Scripts are used to automate the scanning task like vulnerability check , detection,enumeration etc. All the scripts in NSE are written in **Lua** language. There are several other scripts to run but from the image below it is a default script used by Nmap.

The output shows:

- Host is up (0.00067s latency)
- Not shown: **997 closed tcp ports**
- **OS: Windows XP**
OS CPE: cpe:/o:microsoft:windows_xp::
Computer name: [REDACTED]

This is **detailed system information leaked**

- smb-security-mode
account_used: guest (weak security)
authentication_level: user
message_signing: disabled

```
[root@kali] ~/home/kali
$ nmap -A 192.168.248.138
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 05:03 -0400
Nmap scan report for 192.168.248.138
Host is up (0.00067s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc      Microsoft Windows RPC
139/tcp    open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Windows XP microsoft-ds
MAC Address: 08:00:2D:1E:4E:7E (VMware)
Device type: general purpose
Running: Microsoft Windows 2000/XP/2003
OS CPE: cpe:/o:microsoft:windows_2000::sp2 cpe:/o:microsoft:windows_2000::sp3 cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_server_2003::sp2 cpe:/o:microsoft:windows_server_2003::sp3
OS details: Microsoft Windows 2000 SP2 - SP4, Windows XP SP2 - SP3, or Windows Server 2003 SP0 - SP2
Network Distance: 1 hop
Service Info: OS: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: 2h55m2s, deviation: 2h52m2s, median: 5h30m02s
|_ smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::
|_ Computer name:
|_ NetBIOS computer name:
|_ NetBIOS name: [REDACTED]
|_ System time: 2026-05-04T16:33:32+05:30
|__host: NetBIOS name: [REDACTED], NetBIOS user: <unknown>, NetBIOS MAC: [REDACTED] (VMware)
|_ smb-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT      ADDRESS
0  1.30 ms  192.168.248.1
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 23.20 seconds

[root@kali] ~/home/kali
```

3. What Attackers Look for in Results ?

Raw Nmap output is just data. What matters is what an attacker reads into that data. Open ports reveal attack surface. Port 22 open means SSH is running.

- Service versions are the most valuable output. An outdated Apache, OpenSSL, or MySQL version directly maps to public CVEs. This is how most real attacks begin.
- OS information helps attackers choose the right exploit. Windows XP systems are highly vulnerable due to outdated security mechanisms. A modern patched Ubuntu is much harder to attack directly.
- Port 3389 open (RDP) on a Windows machine is an immediate red flag.
- Port 445 open (SMB) on Windows is another high-value finding the exploit behind WannaCry, targets exactly this port.
- Filtered ports mean a firewall is blocking them — but the host is still alive.

4. Nmap Scripting Engine (NSE)

4.1 What is NSE?

The Nmap Scripting Engine (NSE) allows Nmap to go far beyond basic port scanning. NSE scripts can detect vulnerabilities, brute-force credentials, enumerate shares, check for malware backdoors, and much more. Scripts are written in Lua and come bundled with Nmap.

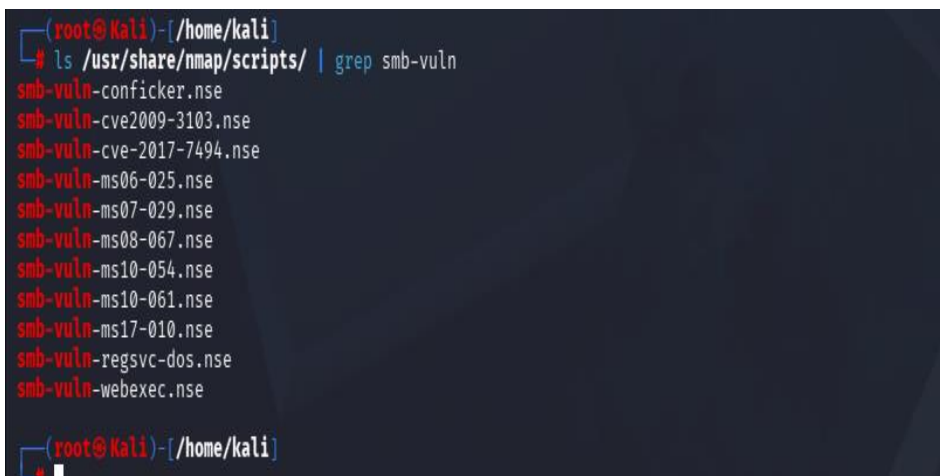
4.2 Script Commands

4.2.1 How to know Where Scripts Are Stored: “/usr/share/nmap/scripts/” in Kali Linux.



4.2.2 To know if the script is present in NSE: This command is used to verify if a specific NSE script exists. The “ls” command lists all available scripts, while grep filters the output to display only matching script name.

```
"ls /usr/share/nmap/scripts/ |grep <script>"
```



4.2.3 Run vulnerability detection scripts:

```
"nmap --script vuln <target>"
```

The command “nmap --script vuln <target>” is used in Nmap to automatically detect known security vulnerabilities on a target system. It is typically used after identifying open ports and services, because at that point we know *what* is running on the system and can now check if those ports are vulnerable. When this command is executed, Nmap first scans the target, identifies active services, and then runs a set of pre-written “vuln” scripts that test for known weaknesses such as **outdated software, misconfigurations, weak authentication, or publicly known exploits (like SMB vulnerabilities)**. These scripts analyze the responses from the target and report whether a service is vulnerable, safe, or requires further investigation.

The output of the NSE script from the image is:

- **smb-vuln-ms17-010 (EternalBlue):** “Remote Code Execution vulnerability in Microsoft SMBv1 servers” (ms17-010). Target is vulnerable to **MS17-010**, this is the famous **EternalBlue vulnerability**
- **Risk Level:** HIGH
- **smb-vuln-ms08-067:** “Microsoft Windows system vulnerable to remote code execution (MS08-067)”, another serious Windows vulnerability, which allows remote attackers to run code.

```

kali@kali: ~$ nmap -sC -sV 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 00:54 -0400
Nmap scan report for 192.168.248.130
Host is up (0.0018s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:FD:EA:7E (VMware)

Host script results:
_smb-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
_smb-vuln-ms10-054: false
_smb-vuln-ms17-010:
  VULNERABLE:
    Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
    State: VULNERABLE
    IDs: CVE:CVE-2017-0143
    Risk Factor: HIGH
    A critical remote code execution vulnerability exists in Microsoft SMBv1
    servers (ms17-010).

    Disclosure date: 2017-03-14
    References:
      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
      https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
_smb-vuln-ms08-067:
  VULNERABLE:
    Microsoft Windows system vulnerable to remote code execution (MS08-067)
    State: VULNERABLE
    IDs: CVE:CVE-2008-4250
    The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
    Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
    code via a crafted RPC request that triggers the overflow during path canonicalization.

    Disclosure date: 2008-10-23
    References:
      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
      https://technet.microsoft.com/en-us/library/security/ms08-067.aspx

```

4.2.4 Enumerate SMB shares:

"nmap --script smb-enum-shares <target>"

It is used in Nmap to identify and list shared resources (folders) on a target system using the SMB protocol. After confirming that SMB services (ports 139 or 445) are open. The purpose of this command is to discover what files or directories are being shared over the network. If the system is misconfigured, it may reveal shared folders such as IPC\$, ADMIN\$, or user directories. The output may also indicate permissions like **read or write access**. This command is particularly useful because it helps identify sensitive data exposure and weak access controls. Attackers often use this information to explore file contents, extract confidential data, or move laterally within a network.

```

kali@kali: ~$ nmap --script smb-enum-shares 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 01:37 -0400
Nmap scan report for 192.168.248.130
Host is up (0.00040s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:FD:EA:7E (VMware)

```

4.2.5 Check for EternalBlue (MS17-010):

"nmap --script smb-vuln-ms17-010 <target>"

It is used to check whether a target system is vulnerable to the **MS17-010 SMB vulnerability**, commonly known as **EternalBlue**. This vulnerability affects Microsoft Windows systems that use the SMBv1 protocol and allows attackers to execute malicious code remotely without authentication.

Nmap first checks whether the SMB service is active on the target system, usually on **port 445**. The script then sends SMB requests to analyze how the target responds. Based on these responses, the script determines whether the system is vulnerable to the MS17-010 flaw.

EternalBlue became widely known because it was used in major cyberattacks such as the **WannaCry ransomware attack**. If a system is vulnerable, an attacker may be able to gain unauthorized access and execute arbitrary code remotely, potentially taking complete control of the system.

The Output of the following command:

- **VULNERABLE:** “Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)”, the system is vulnerable to **MS17-010** also known as **EternalBlue**. Where attackers can run malicious code remotely without authentication.
- **IDs:** **CVE-2017-0143**.
- **Disclosure date:** Microsoft publicly disclosed the vulnerability on **2017-03-14**.

```
(root@kali) ~/home/kali
# nmap --script smb-vuln-ms17-010 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 01:36 -0400
Nmap scan report for 192.168.248.130
Host is up (0.0032s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:FD:EA:7E (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 5.92 seconds
```

4.2.6 Brute force SSH login:

```
"nmap --script ssh-brute <target>"
```

It is used to perform a brute-force attack on the SSH service of a target system. It uses the ssh-brute to try multiple username and password combinations in order to identify weak SSH credentials. The command first checks if **SSH (port 22)** is open and then attempts authentication using different login combinations. If valid credentials are found, they are displayed in the output. This technique is used during penetration testing to detect weak passwords and poor authentication security.

```
(root@kali) ~/home/kali
# nmap --script ssh-brute 192.168.248.130
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-05 01:25 -0400
Nmap scan report for 192.168.248.130
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 00:0C:29:FD:EA:7E (VMware)
```


4.3 What Are Scripts Used For?

- **Vulnerability detection** — scripts like smb-vuln-ms17-010 directly check if a machine is vulnerable to EternalBlue without actually exploiting it.
- **Service enumeration** — scripts reveal hidden details like SMB shares, FTP banners, HTTP headers, and database names.
- **Credential testing** — brute force scripts test common username and password combinations against SSH, FTP, and web login pages.

5. How Defenders Detect and Respond to Nmap Scans

Understanding how Nmap works also helps defenders protect against it. Here is what a blue team does when Nmap scanning is detected:

- **IDS/IPS rules** — Snort and Suricata have built-in rules that detect SYN scan patterns, port sweep behaviors, and NSE script signatures.
- **Firewall filtering** — blocking ICMP ping requests makes host discovery harder. Closing unnecessary ports reduces the attack surface Nmap can map.
- **Rate limiting** — detecting an IP that hits 1000 ports in 10 seconds and automatically blocking it is a simple but effective defense.
- **Honeypots** — setting up fake open ports that trigger alerts the moment someone connects to them catches reconnaissance activity immediately.
- **Log monitoring** — reviewing firewall and IDS logs for sequential port access patterns is a reliable way to catch Nmap scans after the fact.

6. Key Points

- Nmap is used in the reconnaissance phase for “**live hosts, open ports, running services, and operating system details**” .
- SYN scan (-ss) is the most commonly used scan because it never completes the TCP handshake, making it harder to detect.
- Service version detection (-sV) gives the most valuable output knowing an outdated Apache or MySQL version is running directly maps to public CVEs.
- The Nmap Scripting Engine (NSE) extends Nmap beyond scanning it can detect vulnerabilities like “**EternalBlue, enumerate SMB shares, and brute force SSH credentials**”.
- Defenders can detect Nmap activity using IDS/IPS rules, rate limiting, firewall filtering, and honeypots understanding the attacker's tools makes you a better defender.

7. Conclusion

Nmap is not just a tool, it is the starting point of every serious penetration test and real-world attack. An attacker with only Nmap can map an entire network, identify outdated services, detect critical vulnerabilities, and plan a full attack chain, all without triggering a single alert if done carefully.

Every open port is a question. Every service version is an opportunity. Every filtered port is a firewall worth studying. The goal of this writeup was not just to show you how to run scans it was to teach you how to think like a cybersecurity professional.

8. References

1. Nmap Official Documentation - <https://nmap.org/book/man.html>
2. Nmap Scripting Engine Guide - <https://nmap.org/book/nse.html>
3. Penetration Testing: A Hands-On Introduction to Hacking - <https://repo.zenk-security.com/Magazine%20E-book/Penetration%20Testing%20-%20A%20hands-on%20introduction%20to%20Hacking.pdf>
4. Nmap Writeups and Community Articles - <https://medium.com>